Release Safely at Pace

SUMMARY

Release controls that don't slow the process. Everyone knows what is happening and consistency drives the right behaviour. In a regulated medical device the control is not optional, it is the evidence regulators need to trust what you ship.

TECH STACK

GitHub Actions · ACR · TestRail · SonarCloud · Snyk · Syft · Qualio

APPROACH & RECOMMENDATION

Pipeline gates in order: build and unit tests, SonarCloud static analysis, Snyk dependency scan, AI code review, Syft SBOM generation, TestRail trigger, human approval to production. No automated promotion to production.

Three-layer test strategy: unit and integration tests automated via GitHub Actions. System verification in TestRail, requirement to test case to execution to result, this is the IEC 62304 regulatory artefact. Clinical performance validation to FDA submission standard, separate from software verification.

Every sprint produces a release candidate. Production requires PO sign-off, QA gate, and regulatory checklist.

ALTERNATIVES CONSIDERED & REJECTED

Informal test evidence back-filled before submission. The cost of back-filling is always higher than the cost of discipline. Rejected. Fully automated promotion to production. Not compatible with regulated software sign-off requirements. Rejected. Compliance tooling separate from the delivery pipeline. Creates two systems of record, engineers treat compliance as something that happens to them rather than something they own. Rejected.

Trade-off: compliance gates add friction. The compliance agent makes traceability linkage visible at PR time — engineers see the gap before it becomes a submission problem, not after. AI code review without measuring action rate risks becoming noise engineers route around.

Observability

SUMMARY

If something goes wrong in the production you need to know before a clinician does. A failed assessment is not just a UX problem, it is a trust problem. You cannot improve what you cannot see.

TECH STACK

Grafana · Prometheus · Loki · Sentry · PagerDuty · Sentry Mobile SDK

APPROACH & RECOMMENDATION

Cloud: Grafana and Prometheus for infrastructure and service metrics. Loki for structured log aggregation. Sentry for error tracking correlated to specific releases. PagerDuty for on-call routing. Key metrics: assessment success rate, inference latency p50/p95/p99, queue depth, cost per assessment.

Mobile: signal quality telemetry returned post assessment covering SNR per ROI, motion artefact rate, rejection rate, and confidence scores. Sentry mobile SDK for crash rate and B2B integration errors.

Privacy constraint: telemetry is aggregated numbers. Raw video never leaves the device.

ALTERNATIVES CONSIDERED & REJECTED

Azure Monitor only, less flexible for correlating mobile and cloud signals in a single view. No mobile telemetry in phase 1, rejected, without signal quality data from production you are optimising blind. Anecdotal AI ROI measurement is not acceptable in a regulated environment where tooling decisions need evidence.